Module 2: Threat Vectors & Social Engineering

Phishing Attacks

Phishing is the use of deceptive digital communications to trick people into revealing sensitive data, providing credentials, or deploying malicious software. Attackers often spoof legitimate brands or contacts.

- **Business Email Compromise (BEC):** A highly lucrative attack where a threat actor sends an email seeming to be from a known, trusted source (like a vendor or CEO). The goal is often to trick an employee into authorizing fraudulent wire transfers or redirecting payroll.
- **Spear Phishing:** Unlike generic mass-phishing, this is a targeted malicious email attack aimed at a specific user or group. Attackers use Open Source Intelligence (OSINT) to personalize the email, making it highly convincing.
- **Whaling:** A specialized form of spear phishing where threat actors target high-profile company executives (the "whales") to gain access to highly sensitive corporate data or large financial accounts.
- **Vishing (Voice Phishing):** The exploitation of electronic voice communication (phone calls, VoIP) to obtain sensitive information. Attackers may use caller ID spoofing or even AI voice cloning to impersonate a known source.
- **Smishing (SMS Phishing):** The use of text messages to trick users. Common tactics include fake package delivery notifications or urgent bank alerts containing malicious links.

The Malware Landscape

Malware (malicious software) is designed to harm devices, disrupt networks, or gain unauthorized access. Its primary purpose is usually financial gain or intelligence gathering (espionage).

- **Viruses:** Malicious code written to interfere with computer operations. A virus *requires user interaction* to be initiated (e.g., clicking a malicious attachment). It then hides in other files, inserting its code to damage or destroy data when those files are opened.
- **Worms:** Malware that can duplicate and spread itself across systems autonomously. In contrast to a virus, a worm does not need a user to execute it; it actively exploits network vulnerabilities to self-replicate and infect other connected devices.

- **Ransomware:** A severe attack where threat actors encrypt an organization's critical data and demand payment (often in cryptocurrency) for the decryption key. Modern attackers also use "double extortion," threatening to leak the data publicly if the ransom is not paid.
- **Spyware:** Malware used to covertly gather and sell information without consent. It allows threat actors to collect personal data such as keystrokes, private emails, text messages, and even activate device microphones or cameras.

Understanding Social Engineering

Social engineering is a manipulation technique that exploits human psychology and error rather than technical system flaws. Threat actors create environments of false trust to bypass security controls.

- **Social Media Phishing:** Threat actors scrape detailed personal information from targets' public profiles (like LinkedIn or Facebook) to craft highly customized and believable attacks.
- **Watering Hole Attack:** Instead of attacking users directly, threat actors compromise a specific website frequently visited by the target group (e.g., an industry forum), infecting visitors with malware.
- **USB Baiting:** A physical attack where a threat actor strategically leaves a malware-infected USB stick in a visible location (like a parking lot or lobby). They rely on human curiosity for an employee to plug it into the corporate network.
- **Physical Social Engineering:** A threat actor impersonates an employee, maintenance worker, or vendor to bypass physical security (like tailgating through a secure door) and gain unauthorized access to a facility.

Core Principles of Social Engineering

Social engineering is incredibly effective because humans are biologically and socially conditioned to respond to certain behavioral triggers. Threat actors weaponize these principles:

- **Authority:** Threat actors impersonate individuals with power (like law enforcement, IT directors, or executives). People are conditioned to respect and obey authority figures without questioning them.
- **Intimidation:** Using bullying tactics or fear. Attackers persuade and intimidate victims by threatening severe consequences, such as job termination or legal action, if they do not comply.
- **Consensus (Social Proof):** Exploiting the "herd mentality." Threat actors pretend to be legitimate by claiming that others have already complied (e.g., "Three other people in your department already filled out this form").
- **Scarcity:** Creating a fear of missing out (FOMO). Attackers imply that goods, services, or opportunities are in limited supply to rush the victim's decision-making.
- **Familiarity:** Establishing a fake emotional connection or finding common ground with the user to build rapport and lower their defenses.

- **Trust:** Establishing an emotional relationship with a user *over time*. This long-term manipulation (often seen in romance scams or long-con corporate espionage) builds deep trust before requesting sensitive information.
- **Urgency:** Persuading others to respond quickly. By creating an artificial time constraint (e.g., "Your account will be suspended in 10 minutes"), the attacker forces the victim to act before they have time to think critically.